MODUL 5

ATTACKING WEB SERVER

5.1 Tujuan Praktikum

1. Memahami *Web Server.*
2. Mengetahui beberapa jenis *Web Server.*
3. Mengerti tentang Teknik-teknik pengecekan vulnerabilitas seperti:
   a. *Remote File Inclusion* (RFI)
   b. *Local File Inclusion* (LFI)
   c. SQL *Injection*
   d. *Cross Site Scripting* (XSS)
   e. HTTPS
   f. Web Deface
4. Mengetahui beberapa *tools* untuk melakukan pengecekan vulnerabilitas.
5. Dapat memeriksa keamanan *Web Server* dengan teknik *SQL Injection.*

5.2 Alat dan Bahan

1. Laptop
2. Mouse
3. Virtual Box
4. Kali Linux
5. Visual Studio Code
6. XAMPP

5.3 Dasar Teori

5.3.1 Pengenalan *Web Server*

Web Server adalah perangkat lunak pada server yang berfungsi untuk menerima permintaan halaman web melalui HTTP atau HTTPS dari klien, biasanya *browser web*, dan mengirimkan kembali hasilnya dalam bentuk halaman web yang biasanya berformat dokumen HTML. *Web Server* pertama hanya mendukung file statis, seperti HTML dan gambar, tetapi sekarang mereka umumnya memungkinkan penyisipan aplikasi *server-side*. Beberapa

kerangka kerja aplikasi web bahkan mencakup server HTTP sederhana. Dua *web server* yang paling banyak digunakan di seluruh dunia adalah Nginx dan Apache. Masing-masing memegang sekitar 31,2%. Nginx adalah solusi ideal untuk mengelola situs web dengan lalu lintas tinggi dan banyak situs web dan aplikasi berprofil tinggi, seperti Netflix atau Pinterest, menggunakan *web server* Nginx. Apache HTTP Server adalah upaya untuk mengembangkan dan memelihara server HTTP *open-source* untuk sistem operasi modern termasuk UNIX dan Windows. Selain itu, ada juga LiteSpeed Web Server, Microsoft-IIS, dan OpenResty yang merupakan beberapa *web server* populer lainnya.

1. XAMPP Server

   XAMPP adalah sebuah akronim di mana 'X' adalah singkatan dari *Cross-Platform*, 'A' adalah singkatan dari Apache, 'M' adalah singkatan dari MariaDB (sebelumnya MySQL), dan 'P' adalah singkatan dari PHP dan Perl. XAMPP adalah sebuah paket solusi server web lintas platform yang gratis, *open-source*, dan dikembangkan oleh Apache Friends. Paket ini menyediakan lingkungan host lokal yang ideal untuk menguji proyek MySQL, PHP, Apache, dan Perl. Paket ini mencakup Apache HTTP Server, database MariaDB, dan penerjemah untuk skrip yang ditulis dalam bahasa pemrograman PHP dan Perl. XAMPP dirancang untuk menjadi alat yang mudah diatur dan digunakan yang bekerja pada berbagai platform termasuk Windows, Linux, dan MAC OS. Awalnya XAMPP menyertakan DBMS MySQL tetapi sekarang menggunakan MariaDB, DBMS relasional yang banyak digunakan yang dikembangkan oleh MySQL. Meskipun sederhana, dibandingkan dengan server web lain seperti WAMP, konfigurasi dan pengaturan XAMPP bisa jadi lebih menantang.

2. Nginx

   Nginx adalah perangkat lunak *open-source* yang dirilis pada tahun 2004. Perangkat lunak ini dirancang untuk menawarkan penggunaan memori yang rendah dan konkurensi yang tinggi. Daripada membuat proses baru untuk setiap permintaan web, Nginx menggunakan pendekatan asinkron, berbasis peristiwa di mana permintaan ditangani dalam satu utas. Dengan arsitekturnya yang ringan, Nginx terbukti sangat baik untuk menyajikan konten statis dengan cepat dan efisien. Juga mampu menangani lebih dari

10.000 koneksi simultan dengan *footprint* memori yang rendah. Namun, Nginx tidak mendukung pemrosesan konten dinamis secara *native*. Untuk menyajikan konten dinamis, Nginx harus meneruskan permintaan ke server aplikasi yang mendukung bahasa seperti PHP atau Python. Nginx juga dapat bertindak sebagai server proxy terbalik untuk protokol HTTP, HTTPS, SMTP, POP3, dan IMAP, serta penyeimbang beban dan cache HTTP.

3. Apache HTTP Server

   Apache HTTP Server adalah perangkat lunak *open-source* yang bertujuan untuk menyediakan server yang aman, efisien, dan dapat diperluas yang menyediakan layanan HTTP yang selaras dengan standar HTTP yang ada saat ini. Apache mendukung berbagai fitur yang sebagian besar diimplementasikan sebagai modul yang dikompilasi yang memperluas fungsionalitas inti. Mulai dari dukungan bahasa pemrograman sisi server hingga skema autentikasi. Namun, Apache membuat utas baru untuk setiap permintaan, yang menyebabkan penggunaan memori yang signifikan ketika menangani banyak koneksi simultan. Apache kompatibel dengan hampir semua sistem turunan UNIX seperti Linux, Solaris, Mac OS X, dan juga sistem Windows.

4. LiteSpeed Web Server

   LiteSpeed Web Server adalah perangkat lunak berpemilik yang dirancang untuk menjadi pengganti Apache dengan kinerja yang lebih tinggi. Ini bertujuan untuk menjadi cepat dan efisien dalam hal kecepatan pemrosesan dan penggunaan memori. LiteSpeed dapat menangani ribuan koneksi dengan konsumsi memori yang minimal. Ini kompatibel dengan sebagian besar fitur Apache termasuk mod_rewrite, .htaccess, dan mod_security. Namun, LiteSpeed bukan open-source dan membutuhkan lisensi setelah masa percobaan.

5. Microsoft-IIS

   Microsoft-IIS (*Internet Information Services*) adalah perangkat lunak berpemilik untuk Windows® Server yang berfungsi sebagai server Web

yang fleksibel, aman, dan dapat dikelola untuk meng-*hosting* apa pun di Web. IIS terintegrasi erat dengan sistem operasi Windows, memberikan manfaat seperti daur ulang proses, manajemen identitas, dan perlindungan kegagalan yang cepat. Namun, IIS terbatas pada platform Microsoft dan tidak mendukung sistem operasi lain seperti Linux atau macOS. IIS mendukung protokol HTTP, HTTP/2, HTTPS dan memiliki arsitektur modular yang memungkinkan Anda menambahkan, menghapus, dan mengganti fitur server Web sesuai kebutuhan. IIS juga dapat memanfaatkan fitur dan ekstensibilitas ASP.NET 2.0 untuk aplikasi Web yang berjalan di server dan memiliki kemampuan diagnostik untuk pelacakan kesalahan. Kelebihannya adalah kompatibilitas tinggi dengan Windows dan kinerja yang baik untuk PHP, SSL, dan halaman statis. Namun, IIS kurang tangguh dan mudah mengalami 'hang', sehingga server harus di-restart untuk pulih.

6. OpenResty

   OpenResty adalah perangkat lunak *open-source* yang bertujuan untuk menjalankan aplikasi web sisi server Anda sepenuhnya di server Nginx. OpenResty memanfaatkan model event Nginx untuk melakukan I/O non-blocking tidak hanya dengan klien HTTP tetapi juga dengan backend jarak jauh seperti MySQL, PostgreSQL, Memcached, dan Redis. OpenResty secara efektif mengubah server nginx menjadi server aplikasi web yang kuat. Para pengembang dapat menggunakan bahasa pemrograman Lua untuk membuat skrip berbagai modul nginx C dan modul Lua yang sudah ada. Namun, mungkin ada kesenjangan pengetahuan bagi para pengembang yang tidak terbiasa dengan bahasa pemrograman Lua atau modul-modul Nginx.

5.3.2 *Vulnerability*

Vulnerability atau celah keamanan adalah suatu kelemahan yang mengancam nilai *integrity*, *confidentiality* dan *availability* dari suatu asset. *Vulnerability* tidak hanya berupa *software bugs* atau kelemahan *security* jaringan. Namun kelemahan seperti pegawai yang tidak ditraining, dokumentasi yang tidak tersedia maupun prosedur yang tidak dijalankan

dengan benar. *Vulnerability* bisa dikategorikan ke dalam tiga bagian, yaitu kelemahan pada sistem itu sendiri, jalur akses menuju kelemahan sistem, serta kemampuan dari seorang *hacker* untuk melakukan *attacking*.

5.3.3 HTTPS

HTTPS (HTTP *Secure*) adalah versi yang lebih aman dari HTTP, protokol komunikasi utama yang digunakan oleh *World Wide Web*. HTTPS dirancang oleh Netscape Communications Corp. untuk menyediakan autentikasi dan komunikasi yang dienkripsi. Berbeda dengan HTTP yang menggunakan komunikasi teks biasa, HTTPS mengenkripsi data sesi menggunakan protokol SSL (*Secure Socket Layer*) atau TLS (*Transport Layer Security*). Kedua protokol ini memberikan perlindungan yang memadai terhadap serangan *eavesdroppers* dan serangan "*man in the middle*". Secara umum, HTTPS menggunakan port 443.

Namun, teknologi ini terus berkembang. Misalnya, ada standar baru seperti HTTP/2 dan HTTP/3 yang dirancang untuk meningkatkan kecepatan dan efisiensi komunikasi web, serta memperkuat keamanannya. Selain itu, ada juga peningkatan dalam teknologi enkripsi dan autentikasi, termasuk penggunaan sertifikat digital yang lebih canggih dan algoritma enkripsi yang lebih kuat.

5.3.4 *Web Deface*

Web Deface dapat diartikan sebagai aktivitas merubah isi suatu halaman web yang bukan haknya dengan kalimat, gambar, atau link tertentu yang tidak ada sangkut-pautnya dengan misi web tersebut. Biasanya peretas men-*deface* suatu halaman web memiliki maksud supaya eksistensinya diketahui oleh khalayak ramai.

Tujuan *hacker* melakukan *deface website*: Ada beberapa alasan mengapa *hacker* melakukan *deface website*, seperti menunjukan kelemahan keamanan, melakukan propaganda agama dan politik, menjual produk, atau hanya untuk kesenangan pribadi.

Ada dua jenis serangan *deface*, yaitu *Full Deface* dan *Partial Deface*. *Full Deface* adalah serangan yang merubah website secara keseluruhan, sedangkan *Partial Deface* hanya merubah Sebagian halaman saja.

Beberapa cara yang bisa dilakukan untuk melindungi website dari *defacement* antara lain melakukan audit keamanan, melakukan update rutin, membuat *credential login* yang sulit, melakukan backup secara berkala, *scan malware* secara rutin, Kelola hak akses user, matikan *debugging mode*, gunakan HTTPS, dan lindungi website dari injeksi SQL.

Jika website Anda terkena *deface*, beberapa langkah yang bisa dilakukan antara lain mengunci website Anda, melakukan pengecekan, membersihkan website dari kode dan file yang buruk, serta memperbarui semua *credential login* sistem admin.

5.3.5 *Cross Site Scripting*

Cross site scripting adalah kelemahan keamanan yang terjadi pada penggunaan teknologi *dynamic page*. *Cross site scripting* dapat diartikan sebagai kelemahan yang terjadi akibat ketidak mampuan server dalam memvalidasi input yang diberikan oleh pengguna.

Algoritma, yang digunakan untuk pembuatan halaman yang diinginkan, tidak mampu melakukan penyaringan terhadap masukkan tersebut. Hal ini memungkinkan halaman yang dihasilkan menyertakan perintah yang sebenarnya tidak diperbolehkan.

Cross site scripting merupakan kelemahan yang populer untuk dieksploitasi. Namun sayangnya, banyak penyedia layanan yang tidak mengakui kelemahan tersebut dan melakukan perubahan pada sistem yang mereka gunakan. Citra penyedia layanan merupakan harga yang dipertaruhkan ketika mereka mengakui kelemahan tersebut. Sayangnya dengan tindakan ini konsumen atau pengguna menjadi pihak yang dirugikan

Salah satu contoh XSS yang terkenal adalah serangan Samy Worm pada tahun 2005, yang memanfaatkan kelemahan Stored XSS pada situs jejaring sosial MySpace. Serangan ini membuat setiap pengguna yang melihat profil Samy menjadi temannya dan menambahkan pesan "*but most of all, samy is my hero*" ke profil mereka. Serangan ini berhasil menginfeksi lebih dari satu juta pengguna dalam waktu kurang dari 24 jam

Beberapa cara yang dapat dilakukan untuk mencegah XSS antara lain melakukan validasi dan sanitasi input pengguna di sisi server, menggunakan *encoding output* yang sesuai dengan konteks, mengimplementasikan kebijakan keamanan konten (CSP) untuk mencegah eksekusi skrip yang tidak dipercaya, dan menggunakan fitur-fitur browser modern seperti SameSite cookies dan Subresource Integrity (SRI).

5.3.6 *File Inclusion*

Local File Inclusion (LFI) dan *Remote File Inclusion* (RFI) adalah dua jenis serangan yang memanfaatkan kelemahan dalam aplikasi web1. LFI memungkinkan penyerang untuk membaca file lokal di server, sedangkan RFI memungkinkan penyerang untuk menyertakan file dari sumber eksternal. Keduanya bisa digunakan untuk mendapatkan akses ke file /etc/passwd di sistem operasi Linux, yang berisi informasi tentang pengguna sistem tersebut.

5.3.7 *SQL Injection*

SQL Injection adalah teknik yang memanfaatkan celah keamanan pada aplikasi web dengan menyisipkan kode SQL melalui input pengguna. Teknik ini bisa digunakan untuk melakukan berbagai aksi, seperti membaca, memodifikasi, atau menghapus data dalam database. Celah ini terjadi ketika masukan pengguna tidak disaring secara benar dari karakter-karakter string yang berupa kode SQL.

5.3.8 *Vulnerability Web Scanner Kali Linux Tools*

1. Nikto

   Nikto adalah pemindai kerentanan baris perintah perangkat lunak gratis yang memindai server web untuk mencari file berbahaya/CGI, perangkat lunak server yang sudah ketinggalan zaman, dan masalah lainnya. Dia melakukan pemeriksaan generik dan spesifik jenis server. Dia juga menangkap dan mencetak semua *cookie* yang diterima1. Nikto adalah pemindai server web sumber terbuka yang dapat digunakan untuk mengidentifikasi kerentanan, kesalahan konfigurasi, dan masalah keamanan pada server web2.
2. Burp Suite

Burp Suite adalah aplikasi Java yang menyediakan seperangkat alat untuk pengujian keamanan aplikasi web. Aplikasi ini dapat membantu Anda mengidentifikasi dan mengeksploitasi kerentanan, serta memverifikasi serangan. Ini memungkinkan Anda untuk menggabungkan teknik manual dan otomatis, dan untuk menyesuaikan kemampuannya dengan add-on yang disebut BApps3.

3. SQLMap

   SQLmap merupakan alat sumber terbuka yang digunakan dalam pengujian penetrasi untuk mendeteksi dan mengeksploitasi kerentanan injeksi SQL. Alat ini dilengkapi dengan mesin pendeteksi yang kuat, banyak fitur khusus untuk penguji penetrasi terbaik, dan berbagai macam sakelar termasuk sidik jari basis data, pengambilan data dari basis data, mengakses sistem berkas yang mendasarinya, dan menjalankan perintah pada sistem operasi melalui koneksi di luar pita4.

4. Webkiller v2.0

   Webkiller v2.0 adalah alat sumber terbuka yang digunakan sebagai alat pengumpul informasi. Webkiller digunakan untuk memindai situs web untuk mengumpulkan informasi dan menemukan kerentanan di situs web dan aplikasi web5.

5. A2SV

   A2SV adalah alat sumber terbuka dan gratis yang tersedia di GitHub yang digunakan sebagai alat pengumpul informasi untuk kerentanan SSL. A2SV digunakan untuk memindai situs web untuk mengumpulkan informasi dan menemukan kerentanan SSL di situs web dan aplikasi web.

6. Zeebsploit

   Zeebsploit adalah alat otomatis yang membantu penguji atau pemburu *bug bounty* dalam fase Pemindaian Pengumpulan Informasi dan juga Eksploitasi. Alat Zeebsploit dapat mengumpulkan informasi seperti Info CMS, catatan WHOIS, geolokasi IP, dan masih banyak lagi7.

7. Anubis

   Anubis adalah alat pencacahan subdomain dan pengumpulan informasi di Kali Linux7. Ini tidak terkait dengan dewa Mesir kuno Anubis

8. Nuubi

Nuubi adalah alat berbasis Python yang digunakan untuk pengujian penetrasi. Alat ini melakukan banyak tugas pengumpulan informasi seperti Banner grabbing, Subnetlookup, Cms detection, Certificate Transparency log monitor, DNS lookup, Extract links Recon, GeoIP lookup, HTTP headers, Nmap scan, Subdomain lookup, Traceroute Scan, mencari host yang berbagi server DNS, dan scanner URL dan website.

5.3.9 DVWA

Damn Vulnerable Website Application adalah aplikasi web PHP/MySQL yang *damn vulnerable*. Tujuan utamanya adalah untuk membantu para profesional keamanan untuk menguji kemampuan dan peralatan mereka dalam lingkungan yang legal, membantu para pengembang web untuk lebih memahami proses pengamanan aplikasi web dan membantu para guru/murid untuk mengajar/mempelajari keamanan aplikasi web dalam lingkungan kelas. Tujuan dari DVWA adalah untuk mempraktikkan beberapa kerentanan web yang paling umum, dengan berbagai tingkat kesulitan, dengan antarmuka yang sederhana dan mudah.Sebagai catatan, ada kerentanan yang terdokumentasi dan tidak terdokumentasi pada perangkat lunak ini. Ini memang disengaja. Pengguna dianjurkan untuk mencoba dan menemukan sebanyak mungkin masalah. DVWA web sangat rentan! Jangan mengunggahnya ke folder html publik penyedia hosting atau server yang terhubung ke Internet, karena pihak tidak berwenang dapat melakukan penyalahgunaan. Disarankan untuk menggunakan mesin virtual (seperti VirtualBox atau VMware), yang diatur ke mode jaringan NAT.